PRESIDENCE DE LA REPUBLIQUE

AGENCE NATIONALE DES INFRASTRUCTURES NUMERIQUES ET DES FREQUENCES

DIRECTION GENERALE

DIRECTION DE LA SECURITE ET DE L'INFORMATION

SERVICE SECURITE DES RESEAUX ET DE L'INFORMATION

REPUBLIQUE GABONAISE

Union – Travail – Justice

N°_____/PR/ANINF/DG/DISI/SSRI

RAPPORT TECHNIQUE

Objet : Test de sécurité de l'application Web **SGLP**

TYPE	**RAPPORT TECHNIQUE**		
Observation	**TEST DE SECURITE DE L'APPLICATION WEB SGLP**		
Version	**1.0**		
Niveau de confidentialité	**RESTREINTE**		**DATE : 18/03/2026 SIGNATURE**
Rédaction	M. Yann Ulrich **FERRAO MOMBO**	Agent SSRI (ANINF)	
Pré-validation	M. Jessy Kevin **NGANE OBAME**	Responsable Sécurité Applicative/SSRI	
Validation	M. Hans Tchévi Walter **BOUBATA**	Chef de Service/SSRI	
Diffusion	M. Arnold Gildas **RAMONDET MBOUMBA**	Directeur de la Sécurité et de l'Information	

Table des matières

I. RESUME EXECUTIF 4

II. CONTEXTE ET OBJECTIFS DES TESTS 4

III. METHODOLOGIE 4

IV. VULNERABILITES IDENTIFIEES 5

V. RECOMMANDATIONS 5

VI. ANALYSE DES RISQUES 7

ANNEXES TECHNIQUES 8

1. Résultat du scan avec OWASP ZAP 8

2. Résultat des scans effectués 8

GLOSSAIRE

XSS — Cross-Site Scripting	Faille où un attaquant injecte du code JavaScript malveillant dans une page consultée par d'autres utilisateurs. Permet de voler des cookies, usurper une session, ou modifier l'apparence/comportement d'une page.
CVE — Common Vulnerabilities and Exposures	Identifiant public unique donné à une vulnérabilité connue qui sert à référencer, partager et suivre des failles entre chercheurs, éditeurs et outils de sécurité.
OWASP — Open Web Application Security Project	Organisation à but non lucratif qui publie des guides, listes (ex. OWASP Top 10) et outils pour améliorer la sécurité des applications web et mobiles.
CVSS — Common Vulnerability Scoring System	Méthode normalisée pour noter la gravité d'une vulnérabilité Aide à prioriser les correctifs selon l'impact et la facilité d'exploitation.
CSP — Content Security Policy	En-tête HTTP qui indique au navigateur quelles sources de contenu sont autorisées (scripts, images, frames, etc.). Sert à réduire les risques comme le XSS et le clickjacking.
API — Application Programming Interface	Interface (ensemble de règles) permettant à des logiciels ou services d'échanger des données ou de s'appeler mutuellement
SGLP	Services de Gestion des Libertés Publiques

I. RESUME EXECUTIF

Ce rapport présente une synthèse des vulnérabilités identifiées sur la plate-forme SGLP (Service de Gestion des Libertés Publiques), à partir des tests réalisés par la Direction de la Sécurité et de l'Information de l'ANINF. Il vise à informer les parties prenantes sur les principaux risques de sécurité, leur impact potentiel sur les activités, ainsi que les recommandations à court terme pour renforcer la résilience du système.

Les tests ont révélé plusieurs vulnérabilités d'importance critiques et élevées : il est important de suivre les recommandations techniques pour assurer la mise en production de l'application.

II. CONTEXTE ET OBJECTIFS DES TESTS

Dans le cadre de sa démarche de sécurisation des applications, le projet SGLP a fait l'objet d'une campagne d'évaluation de sécurité menée dans le cadre de la digitalisation des services de gestion des libertés publiques. Les tests ont visé l'application web et ses composants API.

L'objectif principal était d'identifier les failles de sécurité susceptibles d'être exploitées par un attaquant interne ou externe, d'en évaluer la criticité, et de proposer des actions correctives pour réduire le niveau de risque global.

III. METHODOLOGIE

Les tests ont été réalisés en mode **boîte noire et boite blanche**, à l'aide des outils suivants :

- **Nmap / Zenmap** : reconnaissance des ports et services ouverts.
- **Sploitscan** : Outils puissant de tests de répertoire exposé et de fichiers sensibles.
- **OWASP ZAP** : scan de sécurité basé sur le Top 10 OWASP.
- **SecurityHeaders.com** : analyse des en-têtes HTTP.
- **Nikto** : Analyse approfondie des vulnérabilités.
- **Dirb :** Tests des fichiers d'un site web.
- **Nuclei** : scan de sécurité approfondi des vulnérabilités
- **Gobuster :** outil de force brute/recensement de chemins (webdir) et de sous-domaines/dns via wordlists
- **Testssl :** utilitaire en ligne de commande pour tester la configuration TLS/SSL d'un service
- **Shodan :** moteur de recherche pour l'Internet des objets et services exposés.
- **Wappalyser :** Découverte des technologies.

IV. VULNERABILITES IDENTIFIEES

Exposition de /phpmyadmin

V01 : L'interface phpMyAdmin est accessible publiquement. Elle constitue une cible privilégiée pour les attaques (bruteforce, exploitation). Cela expose directement la base de données.

Redirection HTTPS → HTTP (/admin → /admin/login)

V02 : L'application redirige une page sécurisée HTTPS vers une page HTTP non chiffrée. Cela entraîne une perte de confidentialité des échanges lors de l'authentification. Les données sensibles peuvent alors transiter en clair.

Mauvaise configuration des cookies (XSRF-TOKEN, session)

V03 : Les cookies ne possèdent pas les attributs Secure et HttpOnly. Ils peuvent être interceptés ou accessibles via JavaScript. Cela expose les sessions à des attaques XSS et hijacking.

Mauvaise configuration des en-têtes (X-Frame-Options, X-Content-Type-Options)

V04 : Les en-têtes de sécurité essentiels sont absents. Cela expose l'application au clickjacking et à l'interprétation incorrecte des contenus. Ces protections sont critiques côté navigateur.

V. RECOMMANDATIONS

Ce plan de remédiation a été élaborée à la suite d'un audit de sécurité applicative visant à identifier les vulnérabilités présentes, à les classifier selon leur niveau de criticité et à proposer des actions correctives adaptées pour assurer la mise en conformité du système d'information avec les référentiels internationaux en vigueur.

ID Rec	Recommandations	Catégorie OWASP	Priorité	Etat	Date
R01	• Ajouter authentification forte • Renommer ou déplacer l'URL • Désactiver en production si inutile	A05 : Mauvaise configuration de sécurité	Critique	Quick Win	21/03/2026
R02	• Forcer HTTPS sur toute l'application (redirect 301 global) • Activer HSTS • Bloquer tout accès HTTP	A02 : Défaillance cryptographique	Elevé	Quick Win	21/03/2026

R03	Set-Cookie: Secure; HttpOnly; SameSite=Strict	A05 : Mauvaise configuration de sécurité	Elevé	Quick Win	21/03/2026
R04	X-Frame-Options: DENY X-Content-Type-Options: nosniff	A05 : Mauvaise configuration de sécurité	Moyenne	Moyen terme	21/03/2026

CONCLUSION : L'APPLICATION N'EST PAS ELIGIBLE POUR UNE MISE EN PRODUCTION DANS SON ETAT ACTUEL.

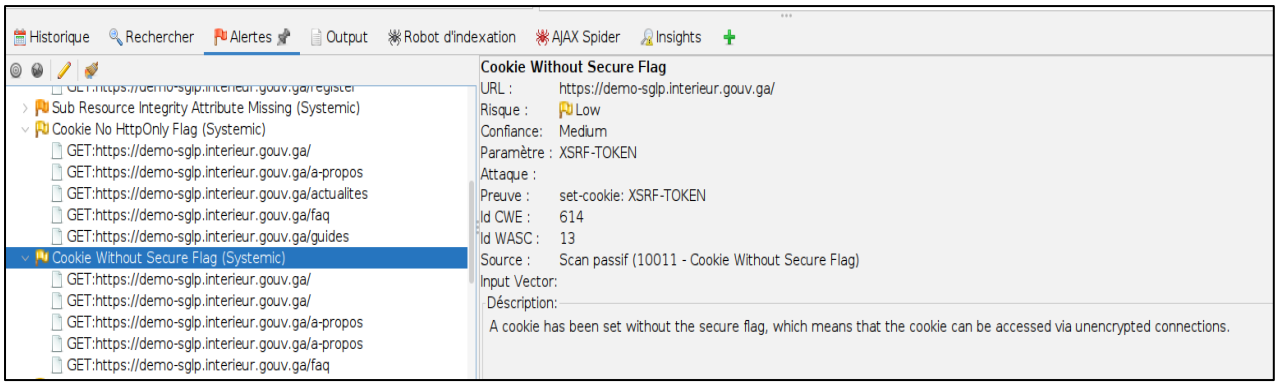
VI. ANALYSE DES RISQUES

REF	Sources de Risques	Cibles de Sécurité / Événement Redouté	Scénario de Menaces	Criticité	OWASP Top 10 (2021) / OWASP Mobile Top 10
V01	Mauvaise exposition d'un outil d'administration.	CS : Confidentialité et intégrité des données. ER : Vol de données	Un attaquant accède à phpMyAdmin et compromet la base de données.	**9.5 CRITIQUE**	A05 : Mauvaise configuration de sécurité
V02	. Mauvaise configuration des redirections HTTP/ HTTPS.	CS : Confidentialité des identifiants ER : interception (MITM)	Un attaquant intercepte la connexion et récupère les identifiants envoyés vers la page HTTP.	**8.7 ELEVEE**	A02 : Défaillance cryptographique
V03	Mauvaise configuration applicative.	CS : Intégrité de session ER : usurpation de session.	Un script malveillant récupère le cookie et prend le contrôle de la session utilisateur.	**8.2 ELEVEE**	A05 : Mauvaise configuration de sécurité
V04	Absence de durcissement HTTP.	CS : Intégrité des actions utilisateur. ER :	Un attaquant charge l'application dans une iframe et trompe l'utilisateur pour exécuter des actions sensibles.	**6.5 MOYENNE**	A05 : Mauvaise configuration de sécurité

ANNEXES TECHNIQUES

Les tests préliminaires effectués font ressortir ce qui suit (prendre en compte les éléments surlignés en jaune).

1. Résultat du scan avec OWASP ZAP



Figures 1,2 : Résultats du scan avec ZAP

2. Résultat des scans effectués

```
┌──(pentest㉿Pentest)-[~]
└─$ cd /opt/nikto/program
perl nikto.pl -h https://demo-sglp.interieur.gouv.ga -Tuning x -C -Display V
- Nikto v2.6.0
---------------------------------------------------------------------------
+ Target IP:          197.231.72.13
+ Target Hostname:    demo-sglp.interieur.gouv.ga
+ Target Port:        443
---------------------------------------------------------------------------
+ SSL Info:           Subject:  /CN=demo-sglp.interieur.gouv.ga
                      CN:       demo-sglp.interieur.gouv.ga
                      SAN:      demo-sglp.interieur.gouv.ga, www.demo-sglp.interieur.gouv.ga
                      Ciphers:  TLS_AES_128_GCM_SHA256
                      Issuer:   /C=US/O=Let's Encrypt/CN=R12
+ Platform:           Unknown
+ Start Time:         2026-03-17 07:52:37 (GMT1)
---------------------------------------------------------------------------
+ Server: Apache
+ [999961] /: Cookie XSRF-TOKEN created without the secure flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ [95] /: Cookie XSRF-TOKEN created without the httponly flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ [999961] /: Cookie pngdi_session_long created without the secure flag. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ [999966] /: The Content-Encoding header is set to "deflate" which may mean that the server is vulnerable to the BREACH attack. See: http://breachattack.com/
+ [999990] OPTIONS: Allowed HTTP Methods: GET, HEAD .
+ 778 requests: 0 errors and 5 items reported on the remote host
+ End Time:           2026-03-17 07:54:22 (GMT1) (105 seconds)
---------------------------------------------------------------------------
```

Figure 3: Résultats du nikto

```
[INF] Templates clustered: 2255 (Reduced 2130 Requests)
[INF] Using Interactsh Server: oast.fun
[phpmyadmin-panel] [http] [info] https://demo-sglp.interieur.gouv.ga/phpmyadmin/ ["4.9.5deb2"] [paths="/phpmyadmin/"]
[cookies-without-httponly] [javascript] [info] demo-sglp.interieur.gouv.ga ["XSRF-TOKEN"]
[cookies-without-secure] [javascript] [info] demo-sglp.interieur.gouv.ga ["XSRF-TOKEN","pngdi_session_long"]
[waf-detect:apachegeneric] [http] [info] https://demo-sglp.interieur.gouv.ga
[CVE-2023-48795] [javascript] [medium] demo-sglp.interieur.gouv.ga:22 ["Vulnerable to Terrapin"]
[ssh-auth-methods] [javascript] [info] demo-sglp.interieur.gouv.ga:22 ["["publickey","password"]"]
[ssh-password-auth] [javascript] [info] demo-sglp.interieur.gouv.ga:22
[ssh-server-enumeration] [javascript] [info] demo-sglp.interieur.gouv.ga:22 ["SSH-2.0-OpenSSH_8.2p1 Ubuntu-4ubuntu0.5"]
[ssh-sha1-hmac-algo] [javascript] [info] demo-sglp.interieur.gouv.ga:22
[openssh-detect] [tcp] [info] demo-sglp.interieur.gouv.ga:22 ["SSH-2.0-OpenSSH_8.2p1 Ubuntu-4ubuntu0.5"]
[tls-version] [ssl] [info] demo-sglp.interieur.gouv.ga:443 ["tls12"]
[tls-version] [ssl] [info] demo-sglp.interieur.gouv.ga:443 ["tls13"]
^[[B[robots-txt] [http] [info] https://demo-sglp.interieur.gouv.ga/robots.txt
[options-method] [http] [info] https://demo-sglp.interieur.gouv.ga ["GET,HEAD"]
[INF] Skipped demo-sglp.interieur.gouv.ga:4040 from target list as found unresponsive permanently: cause="port closed or filtered" address=demo-sglp.interieur.gouv.ga:4040 chain="i/o timeout; got err while executing https://demo-sglp.in
terieur.gouv.ga:4040/jobs/?\"'><script>alert(document.domain)</script>"
[ds-store-file] [http] [info] https://demo-sglp.interieur.gouv.ga/.DS_Store
[addeventlistener-detect] [http] [info] https://demo-sglp.interieur.gouv.ga
[weak-csp-detect:unsafe-script-src] [http] [info] https://demo-sglp.interieur.gouv.ga ["default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval' https://cdn.jsdelivr.net https://cdnjs.cloudflare.com; style-src 'self' 'unsafe-
inline' https://cdn.jsdelivr.net https://cdnjs.cloudflare.com https://fonts.googleapis.com; font-src 'self' https://fonts.gstatic.com https://cdnjs.cloudflare.com; img-src 'self' data: blob: https:; connect-src 'self'; frame-ancestors '
self';"]
[xss-deprecated-header] [http] [info] https://demo-sglp.interieur.gouv.ga ["1; mode=block"]
[apache-detect] [http] [info] https://demo-sglp.interieur.gouv.ga ["Apache"]
[CVE-2022-23134] [http] [medium] https://demo-sglp.interieur.gouv.ga/zabbix/setup.php
[robots-txt-endpoint] [http] [info] https://demo-sglp.interieur.gouv.ga/robots.txt
[missing-sri] [http] [info] https://demo-sglp.interieur.gouv.ga/ ["https://code.jquery.com/jquery-3.6.0.min.js","https://cdn.jsdelivr.net/npm/bootstrap@4.6.2/dist/js/bootstrap.bundle.min.js","https://cdn.jsdelivr.net/npm/bootstrap@4.6.2
/dist/css/bootstrap.min.css","https://cdnjs.cloudflare.com/ajax/libs/font-awesome/6.4.0/css/all.min.css"]
[http-missing-security-headers:clear-site-data] [http] [info] https://demo-sglp.interieur.gouv.ga
[http-missing-security-headers:cross-origin-embedder-policy] [http] [info] https://demo-sglp.interieur.gouv.ga
[http-missing-security-headers:cross-origin-opener-policy] [http] [info] https://demo-sglp.interieur.gouv.ga
[http-missing-security-headers:cross-origin-resource-policy] [http] [info] https://demo-sglp.interieur.gouv.ga
[http-missing-security-headers:missing-content-type] [http] [info] https://demo-sglp.interieur.gouv.ga
[http-missing-security-headers:x-permitted-cross-domain-policies] [http] [info] https://demo-sglp.interieur.gouv.ga
[missing-cookie-samesite-strict] [http] [info] https://demo-sglp.interieur.gouv.ga ["XSRF-TOKEN=eyJpdiI6Imx3dEh4MXdyaWxwa0pDWlA3N0VGVkE9PSIsInZhbHVlIjoiT1RFQnpOb0RlTTBjeUJKN3puYkliaXo4UVVqZ3BsekpXUUkwT215TXFESFBwRXdMdVRQdDBwZWl3NG1HektJ
ZXYwbGNRRTBUVTZCUVplZHpJQVhtanQ1U3JTbUJHbkhoRGcwT0FRQ010dm9nTlNML3c1SjQxNkJxMWijaHVZY3AiLCJtYWMiOiI5NGRkMjUwOTE0N2Y5NWY1YjA1YTNhMTA3YmIwMTdiN2UxMTU1NGVjZmZlMTFhODRhOGY1NTkwOTMyNDE1YjQ4IiwidGFnIjoiIn0%3D; expires=Tue, 17 Mar 2026 12:25:2
7 GMT; Max-Age=7200; path=/; samesite=lax pngdi_session_long=eyJpdiI6InJ0OXI4UFhQa0YvOUoyRGU5b2VpeEE9PSIsInZhbHVlIjoid0FzbFUrNTBQTlM1bERiaTZtYWhrVE54MGVEaFozN0ZKb0JBZ05LNWIwTkczNlg1WnVNbElxUFd1VU1PTUZLaWJHZUF5emFjbCs1ZmFia2k1dmhYeTdJWjB
BL3lkOWpDdVAvTUtMVGtUSGI3ZGt2VXZYbFd2RFFsNU02cTdXNnUiLCJtYWMiOiJkMTBiZTNlZTVlMTU4MzZkMWE1YmJkODkxMjhhZDY1NWU5YzFjNzc4ZmY5NjAwNjMzYmE0OGQ2ODA5ZDFkODU5IiwidGFnIjoiIn0%3D; expires=Tue, 17 Mar 2026 12:25:27 GMT; Max-Age=7200; path=/; httpon
ly; samesite=lax"]
[fingerprinthub-web-fingerprints:landmark-dus] [http] [info] https://demo-sglp.interieur.gouv.ga
[fingerprinthub-web-fingerprints:openfire] [http] [info] https://demo-sglp.interieur.gouv.ga
[tech-detect:font-awesome] [http] [info] https://demo-sglp.interieur.gouv.ga
[tech-detect:bootstrap] [http] [info] https://demo-sglp.interieur.gouv.ga
[tech-detect:jsdelivr] [http] [info] https://demo-sglp.interieur.gouv.ga
[caa-fingerprint] [dns] [info] demo-sglp.interieur.gouv.ga
[ssl-issuer] [ssl] [info] demo-sglp.interieur.gouv.ga:443 ["Let's Encrypt"]
[ssl-dns-names] [ssl] [info] demo-sglp.interieur.gouv.ga:443 ["demo-sglp.interieur.gouv.ga","www.demo-sglp.interieur.gouv.ga"]
[INF] Scan completed in 7m. 37 matches found.
```

Figures 4: Nuclei Test

```
Testing HTTP header response @ "/"

HTTP Status Code            200 OK
HTTP clock skew             -5 sec from localtime
Strict Transport Security   365 days=31536000 s, includeSubDomains
Public Key Pinning          --
Server banner               Apache
Application banner          --
Cookie(s)                   2 issued: NONE secure, 1/2 HttpOnly
Security headers            misconfiguration: X-Frame-Options 2x -- checking first one only
                            X-Frame-Options: SAMEORIGIN
                            misconfiguration: X-Content-Type-Options 2x -- checking first one only
                            X-Content-Type-Options: nosniff
                            Content-Security-Policy: default-src 'self'; script-src 'self' 'unsafe-inline' 'unsafe-eval' https://cdn.jsdelivr.net https://cdnjs.cloudflare.com; style-src 'self' 'unsafe-inline'
                              https://cdn.jsdelivr.net https://cdnjs.cloudflare.com https://fonts.googleapis.com; font-src 'self' https://fonts.gstatic.com https://cdnjs.cloudflare.com; img-src 'self' data: blob: https:; connect-src
                              'self'; frame-ancestors 'self';
                            Permissions-Policy: camera=(), microphone=(), geolocation=()
                            X-XSS-Protection: 1; mode=block
                            Permissions-Policy: camera=(), microphone=(), geolocation=()
                            Referrer-Policy: strict-origin-when-cross-origin
                            Cache-Control: no-cache, private
Reverse Proxy banner        --
```

Figure 5: Test SSL

```
┌──(pentest㉿Pentest)-[~]
└─$ ffuf -u https://demo-sglp.interieur.gouv.ga/FUZZ -w sensible.txt -mc 200,204,301,302,307,401,403 -fc 404 -c -v

        /'___\  /'___\           /'___\
       /\ \__/ /\ \__/  __  __  /\ \__/
       \ \ ,__\\ \ ,__\/\ \/\ \ \ \ ,__\
        \ \ \_/ \ \ \_/\ \ \_\ \ \ \ \_/
         \ \_\   \ \_\  \ \____/  \ \_\
          \/_/    \/_/   \/___/    \/_/

       v2.1.0-dev
________________________________________________

 :: Method           : GET
 :: URL              : https://demo-sglp.interieur.gouv.ga/FUZZ
 :: Wordlist         : FUZZ: /home/pentest/sensible.txt
 :: Follow redirects : false
 :: Calibration      : false
 :: Timeout          : 10
 :: Threads          : 40
 :: Matcher          : Response status: 200,204,301,302,307,401,403
 :: Filter           : Response status: 404
________________________________________________

[Status: 200, Size: 24, Words: 2, Lines: 3, Duration: 13ms]
| URL | https://demo-sglp.interieur.gouv.ga/robots.txt
    * FUZZ: robots.txt

[Status: 403, Size: 199, Words: 14, Lines: 8, Duration: 12ms]
| URL | https://demo-sglp.interieur.gouv.ga/server-status
    * FUZZ: server-status

[Status: 200, Size: 56142, Words: 27523, Lines: 1280, Duration: 832ms]
| URL | https://demo-sglp.interieur.gouv.ga/documents
    * FUZZ: documents

[Status: 302, Size: 430, Words: 60, Lines: 12, Duration: 859ms]
| URL | https://demo-sglp.interieur.gouv.ga/admin
| ---> | http://demo-sglp.interieur.gouv.ga/admin/login
    * FUZZ: admin

:: Progress: [39/39] :: Job [1/1] :: 38 req/sec :: Duration: [0:00:01] :: Errors: 0 ::
```

Figure 6 : Résultats FFUF.

```
┌──(pentest㉿Pentest)-[~]
└─$ curl https://demo-sglp.interieur.gouv.ga/admin
<!DOCTYPE html>
<html>
    <head>
        <meta charset="UTF-8" />
        <meta http-equiv="refresh" content="0;url='http://demo-sglp.interieur.gouv.ga/admin/login'" />

        <title>Redirecting to http://demo-sglp.interieur.gouv.ga/admin/login</title>
    </head>
    <body>
        Redirecting to <a href="http://demo-sglp.interieur.gouv.ga/admin/login">http://demo-sglp.interieur.gouv.ga/admin/login</a>.
    </body>
</html>
```

Figure 7 : Redirection HTTPS vers http coté admin.